Internal Security Audit & Compliance Assessment

Organization: Botium Toys (Fictional Organization)
Course: Google Cybersecurity Professional Certificate
Project: Conduct a Security Audit

---

1. Project Overview

This project involved conducting a simulated internal security audit for Botium Toys, a fictional U.S. company that sells toys through a physical store and an online platform.

The objective was to assess the organization's existing security controls, identify potential risks, and evaluate compliance practices.

The assessment was based on the provided scope, goals, and risk assessment report, using security control categories and compliance best practices.

2. Security Controls Assessment

The following checklist documents the security controls identified as implemented or not implemented at Botium Toys.

Security Control	Yes	No
Least Privilege		✓
Disaster Recovery Plans	✓	
Password Policies	✓	
Separation of Duties		✓
Firewall	✓	
Intrusion Detection System (IDS)		✓
Backups		✓

Antivirus Software	✓	
Manual Monitoring, Maintenance, and Intervention for Legacy Systems		✓
Encryption		✓
Password Management System		✓
Locks (Offices, Storefront, Warehouse)	✓	
Closed-Circuit Television (CCTV) Surveillance	✓	
Fire Detection/Prevention	✓	

3. Compliance Assessment

3.1 Payment Card Industry Data Security Standard (PCI DSS)

Best Practice	Yes	No
Only authorized users have access to customers' credit card information		✓
Credit card information is stored, accepted, processed, and transmitted internally in a secure environment		✓
Data encryption procedures are implemented to secure credit card transaction touchpoints and data		✓
Secure password management policies are adopted		✓

3.2 General Data Protection Regulation (GDPR)

Best Practice	Yes	No
EU customers' data is kept private and secure		✓
A plan exists to notify EU customers within 72 hours of a data breach	✓	
Data is properly classified and inventoried		✓
Privacy policies, procedures, and processes are enforced to document and maintain data	✓	

3.3 System and Organization Controls (SOC 1 and SOC 2)

Best Practice	Yes	No
User access policies are established		✓
Sensitive data (PII/SPII) is kept confidential and private		✓
Data integrity is maintained through consistent, complete, accurate, and validated data		✓
Data is available to individuals authorized to access it		✓

4. Recommendations

Based on the assessment, Botium Toys should prioritize improving its administrative and managerial security controls.

The two main areas requiring attention are:

Separation of Duties

Responsibilities should be distributed among different employees to reduce the risk of unauthorized actions, errors, and misuse of sensitive information.

Principle of Least Privilege

Employees should receive only the minimum system and data access necessary to perform their assigned responsibilities.

Implementing these controls would help strengthen access management and reduce potential security risks.

5. Key Skills Demonstrated

- Security Controls Assessment
- Security Auditing
- Risk Identification
- NIST Cybersecurity Framework
- PCI DSS, GDPR, and SOC
- Access Control and Least Privilege
- Compliance Documentation

6. Conclusion

This simulated security audit provided practical experience evaluating organizational security controls and identifying compliance gaps.

The assessment highlighted the importance of administrative and managerial controls, particularly separation of duties and least privilege, in strengthening an organization's overall security posture.

This project was completed as part of the Google Cybersecurity Professional Certificate using a fictional organization and provided assessment materials. The checklists reflect my original completed coursework.